# Audit et sécurité des systèmes d'information

Informatique — Licence 3 (L3)

Cours INF-L3-24

Institut Africain de Management (IAM) — Bamako, Mali
Bibliothèque Universitaire — Bronbah Tech

**À propos de ce cours**

Conduire un audit de sécurité des systèmes d'information de bout en bout : types d'audit et mandat, méthodologie et collecte de preuves, analyse des risques chiffrée, contrôles techniques et organisationnels, rapport et recommandations, puis suivi des corrections.

Document pédagogique original créé pour les étudiants de l'IAM : leçons détaillées, exemples commentés, travaux dirigés et pratiques, exercices corrigés, QCM d'évaluation et vidéos recommandées. Aucun contenu n'est reproduit d'ouvrages existants.

# Sommaire

• Introduction à la matière
• Objectifs d'apprentissage
• Leçon 1 — Objectifs et types d'audit des systèmes d'information
• Leçon 2 — Méthodologie d'audit et collecte de preuves
• Leçon 3 — Analyse des risques : identification et évaluation
• Leçon 4 — Contrôles techniques et contrôles organisationnels
• Leçon 5 — Rapport d'audit et formulation des recommandations
• Leçon 6 — Suivi des corrections et amélioration continue
• Travaux dirigés (TD)
• Travaux pratiques (TP)
• Exercices corrigés supplémentaires
• QCM d'évaluation
• Résumé — les notions importantes
• Vidéos associées aux leçons
• Sources et références

Comment utiliser ce cours : lis chaque leçon dans l'ordre, refais les exemples à la main, tente chaque exercice AVANT de lire son corrigé, puis termine par le QCM pour vérifier ce que tu as retenu.

# Introduction à la matière

Un système d'information peut sembler bien protégé — antivirus installé, mots de passe en place, sauvegardes « qui tournent » — et pourtant présenter des failles béantes que personne n'a jamais vérifiées : sauvegardes impossibles à restaurer, comptes d'anciens employés toujours actifs, responsabilités floues en cas d'incident. L'audit de sécurité existe précisément pour passer de l'impression à la preuve : il examine, de manière méthodique et indépendante, si les protections annoncées existent réellement et si elles fonctionnent.

Ce cours enseigne l'audit comme une démarche professionnelle et encadrée. Un audit n'est jamais une initiative personnelle : il naît d'un mandat écrit qui définit qui demande l'audit, ce qui sera examiné, ce qui est hors périmètre, et comment les résultats seront utilisés. Nous travaillerons de bout en bout sur le cas fictif de Sahel Négoce SARL, une PME de négoce de Bamako d'une quarantaine de salariés, dont le système d'information servira de fil rouge : plan d'audit, grille de preuves, matrice de risques chiffrée, rapport et tableau de suivi.

Le cours suppose les bases de sécurité vues en L2 et L3 (authentification, sauvegardes, réseaux, droits du numérique) et les met en perspective : il ne s'agit plus seulement de protéger, mais de démontrer que l'on protège, avec des preuves datées et des contrôles testés. À l'issue du cours, tu sauras structurer une mission d'audit complète à taille de PME, hiérarchiser les risques par le calcul, et formuler des recommandations qu'une direction peut décider et qu'un suivi peut vérifier.

# Objectifs d'apprentissage

À la fin de ce cours, tu seras capable de :

- Distinguer les types d'audit (interne, externe, conformité, technique) et leurs objectifs.
- Expliquer pourquoi un audit exige toujours un mandat écrit, un périmètre et des règles d'engagement.
- Appliquer une méthodologie d'audit en phases : préparation, réalisation, restitution, suivi.
- Collecter, référencer et conserver des preuves d'audit recevables et traçables.
- Construire une matrice de risques (probabilité × impact) et calculer des criticités cohérentes.
- Classer les contrôles (techniques ou organisationnels ; préventifs, détectifs, correctifs) et tester leur efficacité.
- Rédiger des constats et des recommandations structurés, puis suivre leur correction dans le temps.

# Leçon 1 — Objectifs et types d'audit des systèmes d'information

Auditer, c'est examiner de façon méthodique et indépendante un système, des processus et des documents, puis comparer ce que l'on observe à ce qui devrait être. Le « devrait être » s'appelle le référentiel : une politique de sécurité interne, une exigence réglementaire, ou un cadre reconnu comme la famille de normes ISO/IEC 27000 ou le référentiel COBIT pour la gouvernance. L'auditeur ne donne pas son opinion au hasard : il formule des constats étayés par des preuves, et ses conclusions doivent pouvoir être revérifiées par un tiers à partir de son dossier de travail.

On classe les audits selon plusieurs axes. Selon l'origine : l'audit interne est mené par des personnes de l'organisation (ou mandatées par elle) pour s'améliorer ; l'audit externe est conduit par un organisme indépendant, par exemple en vue d'une certification ; l'audit « seconde partie » est celui qu'un client mène chez son fournisseur. Selon l'objet : l'audit de conformité vérifie le respect de règles définies ; l'audit de gouvernance interroge les responsabilités et les décisions ; l'audit technique examine des configurations et des mécanismes concrets, toujours dans le périmètre autorisé. Ces catégories se combinent : une PME peut commander un audit externe de conformité sur ses accès et ses sauvegardes.

Première règle du métier, qui conditionne toutes les autres : pas d'audit sans mandat écrit. Le mandat — lettre de mission — précise le commanditaire, le périmètre exact (systèmes, sites, période), les exclusions, les méthodes autorisées, le calendrier, les livrables et le traitement des informations sensibles recueillies. Ce document protège tout le monde : l'audité sait ce qui sera examiné, l'auditeur prouve qu'il agit avec autorisation, et les accès aux données restent proportionnés au besoin. Examiner un système sans autorisation écrite, même « pour aider », sort du cadre de l'audit et peut engager la responsabilité de celui qui le fait. Tout ce cours se place dans ce cadre : défensif, autorisé, documenté.

**L'essentiel**
Un audit compare la réalité observée à un référentiel, avec des preuves. Il existe des audits internes, externes, de conformité, de gouvernance et techniques. Aucun audit ne démarre sans mandat écrit définissant périmètre, méthodes autorisées et livrables.

## Exemple — Lettre de mission et plan d'audit — Sahel Négoce SARL (entreprise fictive)

```
LETTRE DE MISSION – AUDIT DE SECURITE DU SI (extrait)
Commanditaire : Direction generale de Sahel Négoce SARL
Auditeur : Cellule audit interne + prestataire externe
Date d'emission: 03/03/2026 – Periode auditée : 01/01/2025 au 28/02/2026

PERIMETRE INCLUS
- Application de facturation et base clients (serveur SRV-GES01)
- Gestion des comptes et des mots de passe (40 utilisateurs)
- Sauvegardes : politique, exécution, tests de restauration
- Postes de travail du service commercial et de la comptabilité
PERIMETRE EXCLU
- Systeme de vidéosurveillance ; donnees personnelles des salaries
METHODES AUTORISEES
- Entretiens, revue documentaire, observation sur site
- Extraction en lecture seule des journaux et des listes de comptes
- Aucun test d'intrusion ; aucun accès hors présence d'un référent
LIVRABLES
- Rapport d'audit avec constats priorisés (au plus tard le 17/04/2026)
- Reunion de restitution avec la Direction
Confidentialité : les preuves collectées sont conservées sous scellé
numérique par l'auditeur et détruites 12 mois après la restitution.
```

## À retenir

- Un audit compare l'observé à un référentiel et ne conclut que sur preuves.
- Le mandat écrit précède tout : périmètre, exclusions, méthodes autorisées, livrables, confidentialité.
- Interne, externe, conformité, gouvernance, technique : les types d'audit se combinent selon le besoin.

## Exercice

Une connaissance, gérante d'une boutique, te demande « de regarder discrètement, ce week-end, si le logiciel de caisse de son employé est bien configuré et s'il ne détourne pas d'argent — sans le lui dire ». Explique, en t'appuyant sur les notions de la leçon, pourquoi tu ne peux pas accepter en l'état, et propose la démarche correcte à la place (mandat, périmètre, type d'audit adapté).

**✔ Corrigé**
Trois problèmes se cumulent. D'abord, il n'y a aucun mandat écrit : examiner le poste et les données d'une personne à son insu, hors de tout cadre, n'est pas un audit mais une surveillance clandestine, qui peut violer la vie privée et le droit du travail ; en cas de litige, les « preuves » ainsi obtenues seraient fragiles, voire irrecevables. Ensuite, le périmètre et les méthodes ne sont pas définis : que peut-on ouvrir, copier, conserver ? Enfin, la suspicion de fraude relève d'une démarche encadrée (direction, éventuellement conseil juridique et, si les faits se confirment, voies légales), pas d'une inspection improvisée. Démarche correcte : proposer à la gérante un mandat écrit signé par elle en tant que dirigeante — audit interne de conformité du processus de caisse (procédures d'ouverture/fermeture, journaux de caisse produits par le logiciel en lecture seule, rapprochement avec les inventaires) — mené de manière transparente sur le processus, sans ciblage clandestin d'une personne, avec restitution documentée. Si des indices sérieux de détournement apparaissent dans ce cadre, ils sont transmis à la direction, seule habilitée à décider de la suite.

# Leçon 2 — Méthodologie d'audit et collecte de preuves

Une mission d'audit se déroule en phases stables, quelle que soit sa taille. La préparation transforme le mandat en plan de travail : prise de connaissance (organigramme, inventaire des systèmes, politiques existantes), identification préliminaire des risques, choix des contrôles à tester et des preuves à demander, calendrier et liste des interlocuteurs. La réalisation combine trois techniques complémentaires : l'entretien (comprendre les pratiques déclarées), la revue documentaire (vérifier ce qui est écrit : politiques, procédures, rapports) et l'observation ou le test (confronter le déclaratif au réel : une configuration, un journal, une restauration d'essai). La restitution présente les constats, puis le suivi vérifie les corrections — objet de la leçon 6.

La preuve d'audit est le matériau central : sans elle, un constat n'est qu'une impression. Une bonne preuve est pertinente (elle concerne le contrôle testé), fiable (issue d'une source identifiée, difficilement falsifiable) et suffisante (en quantité adaptée au risque). L'auditeur distingue les preuves selon leur force : un journal système horodaté généré automatiquement pèse plus lourd qu'une déclaration orale ; un document signé atteste une décision, mais pas son application réelle. C'est pourquoi l'auditeur croise les sources : il demande la politique de sauvegarde (document), lit le journal des sauvegardes (trace technique) et assiste à un test de restauration (observation) — la convergence des trois fait la solidité du constat.

Chaque preuve collectée est référencée et conservée selon une chaîne de conservation rigoureuse : numéro unique, description, source, date et heure de collecte, personne qui l'a recueillie, et empreinte d'intégrité (par exemple un hachage SHA-256) permettant de prouver qu'elle n'a pas été modifiée ensuite. Les copies de travail sont distinguées des originaux, l'accès au dossier d'audit est restreint, et la durée de conservation est fixée dès le mandat. Cette discipline a une double valeur : elle rend les constats contestables sur le fond mais pas sur la forme, et elle protège

l'audité comme l'auditeur en cas de désaccord ultérieur.

**L'essentiel**
Phases : préparation, réalisation, restitution, suivi. Techniques : entretien, revue documentaire, observation et tests — toujours croisées. Chaque preuve est référencée, horodatée, protégée par une empreinte d'intégrité et conservée selon une chaîne de conservation documentée.

## Exemple — Grille de collecte de preuves — contrôle « sauvegardes » de Sahel Négoce

```
DOSSIER D'AUDIT — MISSION 2026-03 — GRILLE DE PREUVES (extrait)
Contrôle testé : C-07 Sauvegardes quotidiennes + test de restauration
Référentiel : Politique de sauvegarde interne v2.1 (§3 et §4)

Réf | Preuve collectée | Source / origine
------|-------------------------------------|--------------------------
P-101 | Politique de sauvegarde signée v2.1 | Resp. informatique (copie)
P-102 | Journal des sauvegardes, 01-28/02 | SRV-GES01, export lecture seule
P-103 | Capture du paramétrage de la tâche | Observation sur site, 10/03
P-104 | Procès-verbal du test de restauration| Test assisté du 11/03/2026

CHAINE DE CONSERVATION
P-102 : collectée le 10/03/2026 à 09 h 42 par A. Diallo (auditeur)
Empreinte SHA-256 : 9f2c…b41a (valeur complète au dossier)
Stockage : dossier d'audit chiffré, accès auditeurs uniquement
P-104 : collectée le 11/03/2026 à 15 h 07, signée par les deux témoins
présents (auditeur + administrateur système de l'audité)

RESULTAT PRELIMINAIRE DU CONTROLE
Sauvegardes exécutées : 27 nuits sur 28 (journal P-102) — conforme
Dernière restauration testée avant l'audit : 14 mois (P-104 révèle
un échec de restauration du fichier de facturation de février)
-> Constat probable : contrôle partiellement efficace (voir leçon 5)
```

## À retenir

- Préparer, réaliser, restituer, suivre : la méthodologie protège la qualité et la contestabilité des conclusions.
- Croiser entretien, document et observation : une seule source ne suffit presque jamais à conclure.
- Une preuve sans référence, sans date et sans empreinte d'intégrité perd sa valeur en cas de litige.

## Exercice

Lors d'un audit, le responsable informatique affirme : « Les sauvegardes sont faites tous les soirs, c'est certain. » Aucun journal n'est conservé, aucun test de restauration n'a jamais été documenté. 1) Ce témoignage suffit-il à conclure que le contrôle « sauvegardes » est efficace ? 2) Quelles preuves demanderais-tu, par ordre de fiabilité croissante ? 3) Si l'entreprise ne peut fournir que le témoignage, comment l'auditeur doit-il formuler sa conclusion ?

**✔ Corrigé**
1) Non. Le témoignage est la preuve la plus faible : il atteste une conviction, pas un fait. Conclure « efficace » sur cette seule base exposerait l'auditeur si un incident révélait l'absence de sauvegarde. 2) Par fiabilité croissante : la politique écrite de sauvegarde (elle prouve l'intention et les règles, pas l'exécution) ; le paramétrage de la tâche planifiée observé sur le serveur (il prouve que le mécanisme est configuré) ; le journal technique des exécutions sur plusieurs semaines (trace automatique, horodatée, difficile à fabriquer après coup) ; enfin, le test de restauration supervisé, qui seul prouve que la sauvegarde sert à quelque chose le jour où on en a besoin. 3) L'auditeur conclut en nuance traçable : « contrôle non démontré » — l'exécution des sauvegardes n'a pas pu être établie faute de journaux, et l'absence de test de restauration constitue elle-même un constat. Il recommande la journalisation systématique et un test trimestriel documenté. Cette honnêteté méthodologique est précisément ce qui distingue un audit d'une conversation.

# Leçon 3 — Analyse des risques : identification et évaluation

L'audit moderne est fondé sur les risques : on ne peut pas tout contrôler avec la même intensité, donc on concentre l'effort là où un événement redouté ferait le plus de dégâts. L'analyse commence par l'identification : recenser les actifs qui comptent (données de facturation, base clients, application de gestion, réputation), puis, pour chacun, les événements redoutés exprimés en langage simple — perte, divulgation, altération, indisponibilité — et les faiblesses qui les rendent possibles (sauvegardes non testées, comptes partagés, absence de procédure). Un risque bien formulé tient en une phrase : tel événement, sur tel actif, à cause de telle faiblesse, entraînerait tel impact.

Vient ensuite l'évaluation. La méthode pédagogique la plus répandue croise deux échelles : la probabilité (ou vraisemblance) que l'événement se produise dans la période considérée, et l'impact s'il se produit — financier, opérationnel, juridique, d'image. En multipliant les deux notes on obtient une criticité qui permet de hiérarchiser : criticité = probabilité × impact. Des référentiels publics structurent cette démarche, comme la norme ISO/IEC 27005 pour le management du risque ou la méthode EBIOS Risk Manager de l'ANSSI ; quelle que soit la méthode, l'essentiel est que les échelles soient définies avant la notation, appliquées de façon homogène, et que chaque note soit justifiée par un fait observé, pas par une humeur.

L'évaluation produit une matrice de risques et un classement qui pilote tout le reste de la mission : les risques critiques reçoivent des tests approfondis et des recommandations prioritaires, les risques modérés sont surveillés. On calcule aussi le risque résiduel — celui qui subsisterait après mise en place des contrôles recommandés — pour vérifier que le traitement envisagé ramène bien le risque à un niveau acceptable, et pour éclairer la décision de la direction : traiter, éviter, transférer (par exemple via une assurance) ou accepter en connaissance de cause. Un risque accepté se documente et se signe ; un risque ignoré, lui, se paie comptant le jour de l'incident.

**L'essentiel**
Analyser un risque = identifier actif, événement redouté et faiblesse, puis évaluer : criticité = probabilité × impact, sur des échelles définies à l'avance. Le risque résiduel (après contrôles) décide du traitement : traiter, éviter, transférer ou accepter formellement.

## Exemple — Matrice de risques de Sahel Négoce SARL (échelles 1 à 4, calculs vérifiés)

```
ECHELLES (définies avant notation)
Probabilité : 1 rare, 2 possible, 3 probable, 4 quasi certain (sur 12 mois)
Impact : 1 faible, 2 notable, 3 grave, 4 critique pour l'activité
Criticité = P x I | 1-4 MODERE | 5-9 ELEVE | 10-16 CRITIQUE

Ref | Risque (événement redouté / faiblesse) | P | I | Criticité
----|-----------------------------------------------|---|---|----------
R1 | Perte des données de facturation | 3 | 4 | 12 CRITIQUE
| (restaurations jamais testées) | | |
R2 | Divulgation de la base clients | 3 | 3 | 9 ELEVE
| (comptes partagés au service commercial) | | |
R3 | Indisponibilité du serveur de gestion | 2 | 4 | 8 ELEVE
| (matériel unique, sans secours) | | |
R4 | Erreur de saisie comptable non détectée | 4 | 2 | 8 ELEVE
| (aucune relecture avant validation) | | |
R5 | Vol d'un portable professionnel | 2 | 3 | 6 ELEVE
| (disque non chiffré, session sans verrouillage)| | |
R6 | Coupure électrique prolongée au dépôt | 4 | 1 | 4 MODERE
| (pas d'onduleur, activité déplaçable) | | |

RISQUE RESIDUEL APRES CONTROLES RECOMMANDES
R1 : restauration testée chaque trimestre -> I passe de 4 à 2
Criticité résiduelle = 3 x 2 = 6 (ELEVE, surveillé)
R2 : comptes individuels + double authentification -> P passe de 3 à 1
Criticité résiduelle = 1 x 3 = 3 (MODERE, acceptable signé)
```

## À retenir

- Un risque se formule en une phrase : événement + actif + faiblesse + impact.
- Définir les échelles AVANT de noter, justifier chaque note par un fait observé.
- Le risque résiduel décide : traiter, éviter, transférer ou accepter — l'acceptation se signe.

## Exercice

Pour une petite école privée qui gère les notes et la scolarité sur un seul ordinateur au secrétariat, sans sauvegarde externe : 1) formule deux risques complets (événement, actif, faiblesse, impact) ; 2) note-les sur les échelles 1 à 4 de la leçon en justifiant chaque note ; 3) calcule les criticités et classe les risques ; 4) propose pour le risque le plus critique un contrôle qui réduise la probabilité, et un autre qui réduise l'impact, puis calcule la criticité résiduelle dans chaque cas.

**✔ Corrigé**
1) Risque A : « Perte définitive des notes et des dossiers de scolarité (actif : données de l'école) causée par une panne du disque dur unique (faiblesse : aucune copie externe), entraînant l'impossibilité d'établir les bulletins et un litige avec les parents (impact). » Risque B : « Divulgation des informations personnelles des élèves (actif : base élèves) causée par l'absence de mot de passe sur le poste du secrétariat (faiblesse), entraînant un manquement aux obligations de protection des données (impact). » 2) Risque A : probabilité 2 (une panne de disque sur 12 mois est possible, pas probable), impact 4 (données irremplaçables, activité bloquée) → criticité 2 × 4 = 8, ÉLEVÉ. Risque B : probabilité 3 (poste accessible à de nombreuses personnes chaque semaine), impact 3 (atteinte juridique et d'image sérieuse) → 3 × 3 = 9, ÉLEVÉ, classé premier. 3) Classement : B (9) avant A (8). 4) Pour le risque B : réduire la probabilité — compte individuel protégé par mot de passe et verrouillage automatique du poste : P passe de 3 à 1, criticité résiduelle 1 × 3 = 3 (MODÉRÉ). Réduire l'impact — ne conserver sur ce poste que les données strictement nécessaires et archiver le reste sur un support chiffré gardé ailleurs : I passe de 3 à 2, criticité 3 × 2 = 6. La combinaison des deux (3) est meilleure : on traite d'abord la probabilité quand c'est possible et peu coûteux, tout en réduisant l'impact en défense en profondeur.

# Leçon 4 — Contrôles techniques et contrôles organisationnels

Un contrôle est une mesure qui réduit un risque : il empêche l'événement, le détecte, ou en limite les conséquences. On les classe d'abord par nature. Les contrôles techniques sont mis en œuvre par les systèmes : authentification renforcée, chiffrement des disques, journalisation, sauvegardes automatisées, règles de filtrage réseau, gestion des correctifs. Les contrôles organisationnels relèvent des personnes et des règles : politiques écrites, séparation des tâches, procédure d'arrivée et de départ des salariés, sensibilisation, revue périodique des comptes, inventaire des actifs. Confondre les deux familles est une erreur fréquente : acheter un outil ne crée pas de contrôle si aucune procédure ne définit qui l'utilise, qui le vérifie et ce qu'on fait de ses alertes.

On classe aussi les contrôles par fonction dans le temps. Le contrôle préventif agit avant l'événement : exiger un mot de passe robuste et un second facteur empêche l'usage d'un compte volé. Le contrôle détectif repère l'événement pendant ou juste après : les journaux consultés régulièrement, une alerte sur les échecs de connexion répétés, le rapprochement mensuel entre caisse et inventaire. Le contrôle correctif intervient après : restaurer une sauvegarde, désactiver un compte compromis, tirer les leçons d'un incident et modifier la procédure. Un dispositif sain combine les trois fonctions ; une protection uniquement préventive devient aveugle le jour où elle est franchie, faute de détection et de correction préparées.

L'auditeur ne se contente pas de constater qu'un contrôle existe : il en teste l'efficacité. On distingue l'efficacité de conception (le contrôle, s'il est appliqué comme prévu, couvre-t-il le risque ?) et l'efficacité de fonctionnement (est-il réellement appliqué, sur toute la période, avec des traces ?). Les tests sont proportionnés au

risque : revue d'un paramétrage, inspection d'un échantillon de dossiers, ré-exécution d'une opération par l'auditeur, observation d'un test de restauration. Le référentiel ISO/IEC 27002 est souvent utilisé comme catalogue de référence pour ne pas oublier de familles de contrôles — organisation, personnes, physique, technologie — sans jamais recopier son contenu : c'est la réalité de l'entreprise auditée qu'on évalue, pas un texte.

**L'essentiel**
Contrôles techniques (systèmes) et organisationnels (règles et personnes) se complètent ; préventifs, détectifs et correctifs se combinent. L'auditeur teste la conception ET le fonctionnement réel, sur preuves et échantillons proportionnés au risque.

## Exemple — Grille de test des contrôles — mission Sahel Négoce (extrait)

```
Ref | Contrôle testé | Famille / Fonction | Résultat
----|-----------------------------------|--------------------|----------
C-01| Comptes individuels nominatifs | Tech. / Préventif | NON CONFORME
| Test : liste des comptes (P-201) — 3 comptes partagés au commercial
C-02| Revue trimestrielle des accès | Orga. / Détectif | NON CONFORME
| Test : aucune trace de revue sur 12 mois (entretien + documents)
C-03| Désactivation des comptes au départ| Orga. / Préventif | PARTIEL
| Test : échantillon de 5 départs — 4 désactivés, 1 actif après 40 jours
C-04| Sauvegardes quotidiennes | Tech. / Préventif | CONFORME
| Test : journal de février — 27 exécutions réussies sur 28 (P-102)
C-05| Test de restauration trimestriel | Tech. / Correctif | NON CONFORME
| Test : dernier test il y a 14 mois ; restauration d'essai en échec
C-06| Verrouillage automatique des postes| Tech. / Préventif | PARTIEL
| Test : observation de 10 postes — 6 verrouillent à 5 min, 4 jamais
C-07| Sensibilisation des utilisateurs | Orga. / Préventif | PARTIEL
| Test : 1 session en 2025, 18 présents sur 40 (feuille d'émargement)
C-08| Journalisation des connexions | Tech. / Détectif | CONFORME
| Test : journaux présents, horodatés, conservés 12 mois (P-207)

Lecture : 2 conformes, 3 partiels, 3 non conformes sur cet extrait.
Les non-conformités C-01, C-02 et C-05 alimentent les risques R2 et R1.
```

## À retenir

- Un outil sans procédure, sans responsable et sans vérification n'est pas un contrôle.
- Préventif, détectif, correctif : un dispositif équilibré couvre les trois temps du risque.
- Tester = vérifier la conception et le fonctionnement réel, pas cocher l'existence d'un équipement.

## Exercice

Classe chacun de ces contrôles selon les deux axes de la leçon (nature : technique ou organisationnel ; fonction : préventif, détectif ou correctif) : 1) un antivirus à jour sur les postes ; 2) la charte informatique signée par chaque salarié ; 3) la vérification

mensuelle des journaux de connexion par l'administrateur ; 4) la procédure écrite de restauration des sauvegardes ; 5) le chiffrement du disque des portables ; 6) l'alerte automatique envoyée après dix échecs de connexion. Pour le contrôle n° 3, propose un test d'efficacité de fonctionnement.

**✔ Corrigé**
1) Antivirus : technique, préventif (il bloque avant l'infection ; sa fonction de quarantaine après détection serait corrective, mais sa vocation première est préventive). 2) Charte signée : organisationnel, préventif (elle fixe les règles et dissuade ; elle ne détecte rien par elle-même). 3) Revue mensuelle des journaux : organisationnel dans son principe (une personne, une périodicité, une décision) appuyé sur une trace technique ; fonction détective — c'est elle qui repère les anomalies passées. 4) Procédure de restauration : organisationnel, correctif (elle organise le retour à la normale après l'incident ; le test de restauration qui la valide est, lui, un test technique). 5) Chiffrement des disques : technique, préventif (il empêche l'exploitation des données en cas de vol). 6) Alerte sur échecs répétés : technique, détectif. Test pour le n° 3 : demander les comptes rendus ou annotations des revues des trois derniers mois (preuve documentaire), choisir dans les journaux une anomalie réelle de la période et demander ce qui a été décidé à son sujet (traçabilité de la décision), et comparer la date de la revue à la périodicité prévue. Si aucune trace n'existe, le contrôle est peut-être appliqué « de tête » — mais pour un auditeur, non tracé égale non démontré : conclusion « efficacité de fonctionnement non établie ».

## Leçon 5 — Rapport d'audit et formulation des recommandations

Le rapport d'audit est le livrable qui engage l'auditeur : tout ce qui n'y est pas écrit avec soin sera mal compris, contesté ou oublié. Sa structure classique comprend une synthèse pour la direction (périmètre, méthode, appréciation générale, points critiques), le détail des constats, les recommandations priorisées, et en annexe la méthodologie et la liste des preuves. Chaque constat suit une grille rigoureuse en quatre temps : le critère (ce qui devrait être, avec sa source : politique interne, exigence, bonne pratique), la condition (ce qui est observé, avec les preuves référencées), la cause (pourquoi l'écart existe : procédure absente, responsabilité non assignée, outil non configuré), et la conséquence (le risque encouru, relié à la matrice de risques). Un constat sans cause débouche sur des recommandations cosmétiques ; un constat sans conséquence ne convainc aucune direction.

La recommandation répond point par point à la cause : elle décrit l'action attendue, désigne un responsable, propose un délai réaliste et reçoit une priorité héritée de la criticité du risque (critique, élevée, moyenne). Elle doit rester au niveau du « quoi » et du « pourquoi » : l'auditeur recommande « mettre en place des comptes individuels et une revue trimestrielle des accès », il ne dessine pas l'organigramme ni ne choisit le logiciel à la place de l'entreprise. Avant la version finale, les constats sont discutés avec les audités lors d'une réunion de restitution : c'est le moment de corriger les erreurs factuelles, jamais de négocier la disparition d'un constat fondé. La réponse de la direction — accord, plan d'action daté, ou acceptation formelle du risque — est

jointe au rapport : elle transforme des observations en engagements.

La forme compte autant que le fond. Un rapport professionnel est factuel, sans jugement sur les personnes (on audite des processus, pas des individus), sans jargon inutile, et chaque affirmation renvoie à une preuve du dossier. Il distingue clairement les faits, les analyses de l'auditeur et les réponses de la direction. Enfin, sa diffusion est restreinte : un rapport d'audit décrit les faiblesses d'une organisation, c'est donc un document sensible, diffusé aux seules personnes désignées dans le mandat, et conservé selon la même discipline que les preuves.

**L'essentiel**
Un constat = critère, condition (preuves), cause, conséquence. Une recommandation = action, responsable, délai, priorité alignée sur la criticité. Le rapport est factuel, discuté en restitution, complété par la réponse de la direction, et diffusé de façon restreinte.

## Exemple — Extrait de rapport — constat F-03 de la mission Sahel Négoce

```
CONSTAT F-03 — Comptes partagés au service commercial [Priorité : ELEVEE]
Lien : risque R2 (criticité 9) — contrôles C-01 et C-02 non conformes

CRITERE : La politique d'accès interne (v1.4, §2) impose un compte
individuel et nominatif par utilisateur, et une revue
des accès chaque trimestre par le responsable de service.
CONDITION : 3 comptes génériques (« commercial1 » à « commercial3 »)
sont partagés par 9 vendeurs (preuve P-201, liste des
comptes du 10/03/2026). Aucune revue d'accès tracée
sur les 12 derniers mois (entretien E-04, documents).
CAUSE : La création de comptes individuels n'a jamais été
réalisée après le recrutement de 2024, et la revue
trimestrielle n'a pas de responsable désigné.
CONSEQUENCE : Toute action réalisée avec ces comptes est impossible
à attribuer à une personne : en cas de fuite de la base
clients ou d'erreur, ni responsabilité ni enquête fiable
ne sont possibles (risque R2, impact juridique et d'image).

RECOMMANDATION R-03
Action : créer un compte individuel par vendeur, supprimer les
comptes génériques, désigner un responsable de la
revue trimestrielle des accès et tracer chaque revue.
Responsable : Responsable informatique, avec le chef des ventes
Delai : 30 jours pour les comptes ; revue effective sous 90 jours
Priorité : ELEVEE — vérification prévue à l'audit de suivi (leçon 6)
REPONSE DE LA DIRECTION : accord ; plan d'action joint (dates signées).
```

## À retenir

- Critère, condition, cause, conséquence : un constat incomplet produit des recommandations inutiles.
- La priorité d'une recommandation hérite de la criticité du risque, pas de l'humeur du moment.

• On audite des processus, jamais des personnes ; la restitution corrige les faits, elle ne négocie pas les constats.

### Exercice

Voici un constat mal rédigé, tel qu'on le lit parfois : « Le personnel est négligent avec les mots de passe, c'est dangereux, il faut faire attention. » Réécris-le selon la grille critère / condition / cause / conséquence, en inventant des éléments cohérents pour une petite entreprise (politique existante, observation chiffrée issue d'une preuve, cause plausible), puis formule la recommandation complète (action, responsable, délai, priorité). Explique enfin ce qui rendait la version initiale inutilisable par une direction.

**✔ Corrigé**

Version structurée — Critère : la politique de mots de passe interne impose un secret individuel par personne et interdit tout partage ou inscription visible. Condition : lors de l'observation du 12/03 (preuve P-118), 4 postes sur 10 visités portaient un mot de passe inscrit sur un papillon adhésif visible, et deux employés ont déclaré utiliser le même mot de passe que leur collègue de bureau pour « dépanner ». Cause : aucun moyen simple n'est offert pour gérer des mots de passe robustes (pas de gestionnaire de mots de passe), et aucune sensibilisation n'a eu lieu depuis deux ans ; la règle est donc perçue comme inapplicable au quotidien. Conséquence : toute personne traversant les bureaux peut ouvrir une session et agir sous l'identité d'un autre (risque de divulgation et d'actions non attribuables). Recommandation : déployer un gestionnaire de mots de passe d'entreprise, retirer les papillons lors d'une action de sensibilisation de 30 minutes par service, et contrôler l'absence d'inscriptions visibles lors de la revue mensuelle des bureaux. Responsable : responsable informatique ; délai 45 jours ; priorité élevée. La version initiale était inutilisable car elle jugeait des personnes (« négligent ») sans fait mesuré, sans référence à une règle, sans cause — donc sans action possible : une direction ne peut ni décider, ni budgéter, ni vérifier « faites attention ».

## Leçon 6 — Suivi des corrections et amélioration continue

Un rapport d'audit rangé dans un tiroir n'a jamais protégé personne. Le suivi est la phase qui transforme les recommandations en corrections réelles : chaque recommandation devient une ligne d'un plan d'action suivi dans le temps, avec son responsable, son échéance, son état (à lancer, en cours, réalisée, en retard, abandonnée par acceptation du risque) et la preuve de sa réalisation. L'audit de suivi, mené à échéance convenue — souvent six à douze mois plus tard — revérifie sur pièces et sur tests que les corrections annoncées existent et fonctionnent : une attestation du responsable ne suffit pas, l'auditeur ré-applique, en plus léger, les mêmes exigences de preuve qu'à la mission initiale.

Le pilotage du suivi repose sur des indicateurs simples et parlants. Sur notre cas fil rouge : le rapport a émis 12 recommandations ; au point de suivi à six mois, 5 sont clôturées avec preuves, 4 sont en cours, 3 sont en retard. Le taux de clôture vaut 5 ÷

12, soit 41,7 %. En pondérant les recommandations en cours à mi-parcours, l'avancement global estimé vaut (5 × 100 + 4 × 50 + 3 × 0) ÷ 12 = 58,3 %. Ces chiffres ne servent pas à décorer un tableau de bord : ils permettent à la direction de voir, en un coup d'œil, si l'effort est réel, quelles priorités patinent, et où arbitrer — par exemple en traitant d'abord les recommandations liées aux risques critiques avant les améliorations de confort.

Le suivi alimente enfin l'amélioration continue, la boucle qui fait progresser la sécurité d'année en année : les constats récurrents révèlent des causes profondes (manque de temps, de compétences ou de budget récurrent, plutôt que des oublis isolés), les risques sont réévalués dans une matrice actualisée — un risque traité voit sa criticité résiduelle devenir la nouvelle criticité de départ — et le prochain plan d'audit annuel cible les zones où le risque demeure. C'est la logique du cycle « planifier, réaliser, vérifier, agir » que l'on retrouve dans les systèmes de management comme celui de la norme ISO/IEC 27001 : l'audit n'est pas un examen que l'on subit, mais l'instrument de mesure d'un progrès que l'organisation choisit.

**L'essentiel**
Suivre = un plan d'action vivant (responsable, échéance, état, preuve) et un audit de suivi qui revérifie sur tests. Deux indicateurs suffisent pour piloter : taux de clôture et avancement pondéré. Les résultats alimentent la matrice suivante : c'est l'amélioration continue.

## Exemple — Tableau de bord de suivi — mission Sahel Négoce, point à 6 mois

```
SUIVI DES RECOMMANDATIONS — RAPPORT 2026-03 — POINT AU 12/09/2026

Rec | Action (résumé) | Prio | État | Preuve de clôture
----|---------------------------------|--------|------------|------------------
R-01| Tester les restaurations / trim. | CRITIQ.| CLOTUREE | PV de test 06/2026
R-02| Sauvegarde externalisée chiffrée | CRITIQ.| EN COURS | Contrat signé 08/2026
R-03| Comptes individuels (constat F-03)| ELEVEE | CLOTUREE | Liste comptes 05/2026
R-04| Revue trimestrielle des accès | ELEVEE | CLOTUREE | CR de revue 06 et 09
R-05| Verrouillage auto. des postes 5 min| ELEVEE | EN COURS | Déployé sur 8/10
postes
R-06| Serveur de secours (PCA simplifié)| ELEVEE | EN RETARD | Devis en attente
R-07| Sensibilisation annuelle du personnel| MOY. | CLOTUREE | Émargement 07/2026
R-08| Procédure arrivée/départ formalisée| MOY. | CLOTUREE | Procédure v1.0 signée
R-09| Inventaire des actifs à jour | MOY. | EN COURS | Inventaire à 70 %
R-10| Journalisation étendue au dépôt | MOY. | EN RETARD | Non démarrée
R-11| Relecture comptable avant validation| MOY. | EN COURS | Appliquée 2 mois / 3
R-12| Onduleur pour le dépôt | FAIBLE | EN RETARD | Acceptation proposée

SYNTHESE CHIFFREE (calculs vérifiés)
Recommandations : 12 — clôturées 5, en cours 4, en retard 3
Taux de clôture : 5 / 12 = 41,7 %
Avancement pondéré (en cours = 50 %) : (500 + 200 + 0) / 12 = 58,3 %
Risques critiques R1/R2 : R-01 et R-03 closes, R-02 en bonne voie
Décision proposée : R-12 en acceptation formelle du risque R6
(criticité 4, modérée), à signer par la Direction.
```

### À retenir

- Une recommandation sans responsable, sans échéance et sans preuve de clôture est un vœu, pas un plan.
- L'audit de suivi revérifie sur tests : « c'est fait » ne vaut pas preuve.
- Les constats qui reviennent chaque année signalent une cause profonde à traiter, pas des oublis.

### Exercice

Au suivi d'un audit, une entreprise présente le tableau suivant : 20 recommandations au total ; 9 clôturées avec preuves, 6 en cours, 5 en retard. Parmi les 5 en retard, 3 concernent le risque le plus critique du rapport. 1) Calcule le taux de clôture et l'avancement pondéré (en cours = 50 %). 2) Pourquoi l'avancement pondéré seul serait-il un indicateur trompeur ici ? 3) Quelle décision l'auditeur doit-il proposer à la direction, et sous quelle forme ?

**✔ Corrigé**

1) Taux de clôture : 9 ÷ 20 = 45 %. Avancement pondéré : (9 × 100 + 6 × 50 + 5 × 0) ÷ 20 = (900 + 300) ÷ 20 = 60 %. 2) L'avancement de 60 % semble honorable, mais il mélange tout : les recommandations faciles ont pu être closes pendant que le risque majeur reste exposé. Un pourcentage global masque la répartition par priorité ; or la valeur d'un plan de correction se juge d'abord sur les risques critiques. L'indicateur doit donc être présenté par niveau de priorité, et tout retard sur un risque critique doit apparaître en première ligne, pas noyé dans une moyenne. 3) L'auditeur propose une escalade documentée : présentation à la direction du détail des 3 recommandations critiques en retard, avec pour chacune la cause du blocage, une nouvelle échéance courte et ferme (par exemple 30 jours), et le risque résiduel assumé entre-temps. Si la direction choisit de ne pas traiter, ce choix devient une acceptation formelle du risque : écrite, signée, datée, avec une date de réexamen. L'auditeur ne « force » jamais la correction — il rend la décision éclairée, traçable et assumée par le bon niveau.

# Travaux dirigés (TD)

## TD 1 — Audit des comptes utilisateurs d'une clinique privée

Tu audites, sous mandat écrit, la gestion des comptes du logiciel de gestion d'une clinique privée fictive de 60 salariés. La liste extraite en lecture seule le 05/05/2026 (preuve référencée) compte 86 comptes actifs. En la croisant avec le registre du personnel parti entre 2024 et 2026, tu identifies 7 comptes appartenant à d'anciens employés, toujours actifs ; 2 d'entre eux se sont connectés au cours des 30 derniers jours, sans que l'on sache par qui. La politique interne impose la désactivation le jour du départ. Travail demandé : 1) calcule la proportion de comptes orphelins ; 2) rédige le constat complet (critère, condition, cause à vérifier, conséquence) ; 3) propose deux recommandations (une corrective immédiate, une préventive) avec priorités justifiées.

**✔ Corrigé du TD 1**
1) Proportion : 7 ÷ 86 = 8,1 % des comptes actifs sont orphelins — près d'un compte sur douze. 2) Constat — Critère : la politique de gestion des accès impose la désactivation de tout compte le jour du départ du salarié. Condition : à la date d'extraction, 7 comptes d'anciens employés sont actifs (preuve : liste des comptes croisée avec le registre des départs) ; 2 présentent des connexions récentes non attribuables. Cause (à vérifier en entretien) : la procédure de départ ne comporte aucune étape informatique formalisée — les ressources humaines n'informent pas systématiquement le service informatique. Conséquence : des personnes extérieures à la clinique peuvent disposer d'un accès potentiel à des données de santé, hautement sensibles et encadrées ; l'établissement ne peut ni prouver qui a consulté quoi, ni démontrer sa conformité à ses obligations de protection des données. 3) Recommandations — Corrective, priorité CRITIQUE, délai 48 heures : désactiver immédiatement les 7 comptes, examiner les journaux de connexion des 2 comptes utilisés et traiter l'affaire comme un incident de sécurité potentiel (analyse, et décision de la direction sur les suites). Préventive, priorité ÉLEVÉE, délai 30 jours : formaliser une procédure d'arrivée/départ co-signée RH/informatique, avec revue trimestrielle de la liste complète des comptes tracée par un compte rendu. La priorité critique se justifie par l'exposition active : le risque n'est pas théorique, des connexions ont déjà eu lieu.

## TD 2 — Classer et chaîner les contrôles d'une petite banque de données scolaire

Une école supérieure tient ses dossiers d'étudiants dans une application unique. Voici les mesures en place : (a) sauvegarde automatique chaque nuit vers un disque externe resté branché dans le même bureau ; (b) mot de passe unique de 6 caractères pour tous les secrétaires ; (c) procédure écrite de départ du personnel transmise aux RH ; (d) revue semestrielle des comptes par le directeur des études ; (e) test de restauration effectué une fois, il y a deux ans, sans compte rendu ; (f) onduleur protégeant le serveur. Travail demandé : 1) pour chaque mesure, dis si c'est un contrôle, et classe-le (famille, fonction) ; 2) identifie la mesure qui donne une fausse impression de sécurité et explique pourquoi ; 3) propose la chaîne minimale de contrôles (préventif + détectif + correctif) pour le risque « perte des dossiers étudiants ».

**✔ Corrigé du TD 2**
1) (a) Sauvegarde nocturne : contrôle technique, préventif (il prépare la récupération) — mais de portée limitée : le disque restant sur place expose à la perte commune (incendie, vol du bureau). (b) Mot de passe unique partagé et court : ce n'est pas un contrôle satisfaisant, c'est une faiblesse déguisée en mesure : aucun compte individuel, aucune attribution possible ; à reclasser en constat. (c) Procédure de départ transmise aux RH : contrôle organisationnel, préventif — à condition d'être appliquée et tracée, ce que l'auditeur vérifiera sur un échantillon de départs. (d) Revue semestrielle des comptes : contrôle organisationnel, détectif — elle repère les comptes orphelins et les droits excessifs. (e) Test de restauration unique et non documenté : contrôle correctif dans l'intention, mais non démontré — sans compte rendu, impossible de prouver ni sa date ni son résultat. (f) Onduleur : contrôle technique, préventif, contre les coupures brèves et les surtensions. 2) La fausse impression de sécurité vient surtout de (a) combinée à (e) : « nous avons des sauvegardes » rassure tout le monde, mais la copie unique sur place et l'absence de test de restauration récent et tracé font que personne ne sait si la restauration fonctionnerait le jour venu — c'est exactement le risque R1 du cours. 3) Chaîne minimale pour « perte des dossiers » : préventif — sauvegarde automatique quotidienne avec une copie externalisée ou distante ; détectif — journal des sauvegardes consulté chaque semaine et alerte en cas d'échec ; correctif — procédure de restauration écrite et test de restauration trimestriel avec compte rendu signé. Chaque maillon couvre la défaillance du précédent.

# Travaux pratiques (TP)

## TP 1 — Mini-audit complet d'une salle informatique d'établissement scolaire

En binôme et avec l'autorisation écrite de la direction de l'établissement (mandat simplifié fourni par l'enseignant), conduisez un mini-audit de la salle informatique : périmètre limité à l'inventaire des postes, aux comptes utilisés en cours, aux sauvegardes du poste enseignant et aux règles affichées. Étapes : 1) rédiger la lettre de mission d'une page (commanditaire, périmètre, exclusions, méthodes autorisées — observation et entretiens uniquement, aucun test intrusif) ; 2) établir la grille de preuves et la remplir au fur et à mesure (référence, description, source, date et heure) ; 3) tester quatre contrôles au choix dans la liste du cours et documenter chaque test ; 4) identifier trois risques, les noter sur les échelles 1 à 4 et calculer les criticités ; 5) rédiger un mini-rapport de deux pages maximum : un constat complet au format critère/condition/cause/conséquence, deux recommandations avec responsable et délai ; 6) présenter oralement les résultats en cinq minutes, comme en restitution.

**✔ Attendus du TP 1**
Attendus et points de contrôle : la lettre de mission doit exclure explicitement les données personnelles des élèves et tout accès non supervisé — un dossier sans mandat clair est recalé. La grille de preuves doit comporter des références uniques et des horodatages cohérents ; les preuves « de mémoire » ne sont pas acceptées. Les quatre tests doivent croiser au moins deux techniques (par exemple entretien du responsable + observation des postes). Les trois risques doivent être formulés en une phrase complète (événement, actif, faiblesse, impact) et les criticités correctement calculées et classées. Le constat du rapport doit contenir les quatre composantes et renvoyer à des preuves référencées ; les recommandations doivent désigner un responsable et un délai réalistes à l'échelle d'un établissement scolaire. Le jury de la soutenance évalue surtout la traçabilité : chaque affirmation orale doit pouvoir être retrouvée dans le dossier.

# Exercices corrigés supplémentaires

## Exercice 1

Le chiffre d'affaires quotidien moyen de Sahel Négoce est de 450 000 FCFA. Un incident rendant le serveur de facturation indisponible pendant 3 jours ouvrables empêcherait toute facturation (activité non déplaçable). 1) Calcule le manque à gagner brut de cet événement. 2) Le risque R3 (indisponibilité du serveur) était noté probabilité 2, impact 4. Si l'entreprise installe un serveur de secours qui ramène l'indisponibilité maximale à 4 heures, l'impact passe à 1 : recalcule la criticité et la zone. 3) Explique pourquoi ce contrôle agit sur l'impact et non sur la probabilité.

**✔ Corrigé**
1) Manque à gagner brut : 3 × 450 000 = 1 350 000 FCFA (hors coûts annexes : reprises de saisie, pénalités, perte de clients). 2) Nouvelle criticité : 2 × 1 = 2, zone MODÉRÉE (au lieu de 2 × 4 = 8, zone ÉLEVÉE). 3) Le serveur de secours ne réduit en rien la fréquence des pannes du serveur principal — la probabilité de l'événement reste 2. En revanche, il réduit fortement ses conséquences : l'activité reprend en 4 heures au lieu de plusieurs jours, donc l'impact financier et opérationnel s'effondre. C'est la distinction fondamentale entre mesures de prévention (agir sur la probabilité) et mesures de continuité/résilience (agir sur l'impact) ; un plan de traitement équilibré combine les deux selon les coûts.

## Exercice 2

Pendant la collecte de preuves, un auditeur junior fait les choses suivantes : il photographie avec son téléphone personnel l'écran affichant la liste des comptes administrateurs ; il copie le journal des connexions sur une clé USB non chiffrée qu'il emporte chez lui « pour travailler le soir » ; il renomme les fichiers reçus sans garder de trace des noms d'origine. Identifie au moins quatre ruptures de la chaîne de conservation et de la confidentialité, et propose pour chacune la pratique correcte.

**✔ Corrigé**
Rupture 1 — Support personnel : la photographie sur un téléphone privé fait sortir une preuve sensible du périmètre contrôlé (sauvegardes cloud personnelles, perte de l'appareil) ; pratique correcte : capture réalisée avec l'outil prévu par la mission, versée directement au dossier d'audit. Rupture 2 — Copie non chiffrée et déplacement : une clé USB non chiffrée emportée hors site expose des données d'audit confidentielles à la perte et au vol ; pratique correcte : dossier d'audit chiffré, aucun original ni copie ne quitte le cadre défini au mandat sans protection équivalente. Rupture 3 — Renommage sans traçabilité : modifier les noms sans journal détruit le lien entre la preuve et sa source, donc sa valeur probante ; pratique correcte : référence unique attribuée à la collecte, nom d'origine conservé dans la grille de preuves. Rupture 4 — Absence d'empreinte d'intégrité : rien ne permet de prouver que les journaux copiés n'ont pas été modifiés ; pratique correcte : calcul d'un hachage (par exemple SHA-256) au moment de la collecte, consigné dans la grille avec la date, l'heure et l'identité du collecteur. Ces quatre écarts ont en commun de rendre les constats ultérieurs contestables : l'audité pourrait légitimement mettre en doute l'authenticité des pièces.

### Exercice 3

On te présente trois extraits : (A) « L'auditeur estime que la sécurité est globalement moyenne. » (B) « Sur 40 postes inspectés le 10/03/2026 (preuve P-130), 11 ne recevaient plus de mises à jour depuis plus de 90 jours, contrairement à la politique de maintenance v3 (§2) qui impose un délai maximal de 30 jours. » (C) « Il faudrait acheter un logiciel de supervision à 2 000 000 FCFA chez le fournisseur X. » Pour chaque extrait, dis de quel élément du rapport il relève (appréciation, constat, recommandation), s'il est correctement formulé, et corrige ceux qui ne le sont pas.

**✔ Corrigé**
(A) relève de l'appréciation générale, mais il est inutilisable en l'état : « globalement moyenne » ne renvoie à aucun critère ni résultat mesuré. Formulation correcte : la synthèse doit résumer des faits du rapport, par exemple « sur 8 contrôles testés, 2 sont conformes, 3 partiellement conformes et 3 non conformes ; deux risques atteignent la zone élevée ». (B) est un constat correctement formulé : périmètre et date de l'observation, décompte précis, preuve référencée, et critère cité avec sa source — il ne manque que la cause et la conséquence pour être complet. (C) est une recommandation mal formulée : elle prescrit un produit et un fournisseur, ce qui sort du rôle de l'auditeur (conflit d'intérêts possible, et la solution appartient à l'entreprise). Formulation correcte : « mettre en place une supervision centralisée des postes permettant de vérifier le délai de mise à jour et d'alerter au-delà de 30 jours ; responsable : responsable informatique ; délai : 90 jours ; priorité élevée » — le choix de l'outil, libre ou commercial, revient à l'audité.

## QCM d'évaluation

Choisis la bonne réponse pour chaque question. Les corrigés détaillés se trouvent juste après le QCM : ne les regarde qu'après avoir répondu à tout.

1. La première étape de tout audit de sécurité est…

A) Lancer un scan technique du réseau

B) Obtenir un mandat écrit définissant le périmètre

C) Réinitialiser les mots de passe des utilisateurs

2. Un audit « de conformité » vérifie principalement…

A) Le respect de règles et d'exigences définies à l'avance

B) La performance commerciale de l'entreprise

C) La vitesse du réseau local

3. Dans une matrice de risques avec des échelles de 1 à 4, un risque de probabilité 3 et d'impact 3 a pour criticité…

A) 6

B) 7

C) 9

4. La preuve d'audit la plus fiable parmi les suivantes est…

A) Le témoignage oral du responsable informatique

B) Le journal système horodaté généré automatiquement

C) Un courriel affirmant que tout est en règle

5. Un contrôle qui détecte les connexions inhabituelles dans les journaux est un contrôle…

A) Préventif

B) Correctif

C) Détectif

6. La séparation des tâches (celui qui saisit n'est pas celui qui valide) est un contrôle…

A) Organisationnel

B) Technique

C) Physique

7. Dans un rapport d'audit, la « condition » d'un constat désigne…

A) Ce qui devrait être selon le référentiel

B) Ce qui est réellement observé, appuyé par des preuves

C) La sanction encourue par le salarié

8. La priorité d'une recommandation doit dépendre d'abord…

A) De la facilité de mise en œuvre

B) Du coût de la solution

C) De la criticité du risque auquel elle répond

9. À l'audit de suivi, le responsable annonce « c'est corrigé ». L'auditeur doit…

A) Clore la recommandation sur parole

B) Revérifier la correction sur preuves et par des tests

C) Prolonger automatiquement le délai d'un an

10. Si une direction décide de ne pas traiter un risque identifié, la démarche correcte est…

A) L'auditeur supprime le constat du rapport

B) Une acceptation formelle du risque, écrite, signée et datée

C) L'auditeur réalise lui-même la correction

## Corrigés du QCM

1. Réponse B — Sans mandat écrit, il n'y a ni autorisation claire, ni périmètre, ni protection juridique pour l'auditeur comme pour l'audité.

2. Réponse A — L'audit de conformité compare la réalité observée à un référentiel de règles : politique interne, exigences réglementaires ou cadre reconnu.

3. Réponse C — Criticité = probabilité × impact = 3 × 3 = 9, ce qui le place en zone élevée selon les seuils du cours (5 à 9).

4. Réponse B — Une trace technique automatique, horodatée et difficile à fabriquer après coup pèse plus lourd qu'une déclaration, même de bonne foi.

5. Réponse C — Il repère un événement pendant ou après sa survenance : c'est la fonction détective, complémentaire des contrôles préventifs et correctifs.

6. Réponse A — Elle repose sur l'organisation du travail et les responsabilités des personnes, même si un logiciel peut ensuite la faire respecter.

7. Réponse B — Le constat compare le critère (ce qui devrait être) à la condition (ce qui est observé, preuves à l'appui), puis explique la cause et la conséquence.

8. Réponse C — On traite d'abord ce qui expose le plus l'organisation : la priorité hérite de la criticité calculée dans la matrice de risques.

9. Réponse B — Le suivi applique les mêmes exigences que l'audit initial : non tracé égale non démontré, la clôture exige une preuve vérifiable.

10. Réponse B — Accepter un risque est une décision légitime de la direction, à condition d'être éclairée, écrite, signée et réexaminée périodiquement.

# Résumé — les notions importantes

• Un audit compare la réalité observée à un référentiel et ne conclut que sur preuves ; il démarre toujours par un mandat écrit (périmètre, exclusions, méthodes autorisées, livrables).

• Types d'audit : interne, externe, de conformité, de gouvernance, technique — ils se combinent selon le besoin de l'organisation.

• Méthodologie en quatre phases : préparation, réalisation (entretiens, documents, observations et tests croisés), restitution, suivi.

• La preuve d'audit est référencée, horodatée, protégée par une empreinte d'intégrité et conservée selon une chaîne de conservation documentée.

• Analyse des risques : formuler (événement, actif, faiblesse, impact), puis évaluer — criticité = probabilité × impact ; le risque résiduel guide le traitement (traiter, éviter, transférer, accepter formellement).

• Contrôles techniques et organisationnels, préventifs, détectifs et correctifs : l'auditeur teste la conception et le fonctionnement réel, sur échantillons

proportionnés au risque.

• Rapport et suivi : constat en critère/condition/cause/conséquence, recommandations avec responsable, délai et priorité ; le suivi revérifie sur preuves et alimente l'amélioration continue.

# Fiches de révision express

Chaque fiche reprend les points « À retenir » d'une leçon. Relis-les la veille d'un contrôle : cinq minutes par fiche suffisent.

**Fiche 1 — Objectifs et types d'audit des systèmes d'information**
Un audit compare l'observé à un référentiel et ne conclut que sur preuves. ; Le mandat écrit précède tout : périmètre, exclusions, méthodes autorisées, livrables, confidentialité. ; Interne, externe, conformité, gouvernance, technique : les types d'audit se combinent selon le besoin.

**Fiche 2 — Méthodologie d'audit et collecte de preuves**
Préparer, réaliser, restituer, suivre : la méthodologie protège la qualité et la contestabilité des conclusions. ; Croiser entretien, document et observation : une seule source ne suffit presque jamais à conclure. ; Une preuve sans référence, sans date et sans empreinte d'intégrité perd sa valeur en cas de litige.

**Fiche 3 — Analyse des risques : identification et évaluation**
Un risque se formule en une phrase : événement + actif + faiblesse + impact. ; Définir les échelles AVANT de noter, justifier chaque note par un fait observé. ; Le risque résiduel décide : traiter, éviter, transférer ou accepter — l'acceptation se signe.

**Fiche 4 — Contrôles techniques et contrôles organisationnels**
Un outil sans procédure, sans responsable et sans vérification n'est pas un contrôle. ; Préventif, détectif, correctif : un dispositif équilibré couvre les trois temps du risque. ; Tester = vérifier la conception et le fonctionnement réel, pas cocher l'existence d'un équipement.

**Fiche 5 — Rapport d'audit et formulation des recommandations**
Critère, condition, cause, conséquence : un constat incomplet produit des recommandations inutiles. ; La priorité d'une recommandation hérite de la criticité du risque, pas de l'humeur du moment. ; On audite des processus, jamais des personnes ; la restitution corrige les faits, elle ne négocie pas les constats.

**Fiche 6 — Suivi des corrections et amélioration continue**
Une recommandation sans responsable, sans échéance et sans preuve de clôture est un vœu, pas un plan. ; L'audit de suivi revérifie sur tests : « c'est fait » ne vaut pas preuve. ; Les constats qui reviennent chaque année signalent une cause profonde à traiter, pas des oublis.

# Vidéos associées aux leçons

Ces vidéos, en français, complètent les leçons. Liens vérifiés au moment de la publication de ce document.

### Leçon 1 — ISO/IEC 27001 – la sécurité de l'information expliquée simplement

Chaîne : BALTUM · Langue : Français · Niveau : Intermédiaire

Une présentation claire du système de management de la sécurité de l'information (SMSI) et de la place de l'audit dans sa démarche. Parfait pour comprendre, avant de commencer, le référentiel auquel les audits de conformité se comparent.

https://www.youtube.com/watch?v=GHI8Ce04a-Q

### Leçon 3 — L'analyse des risques

Chaîne : HAXXOM · Langue : Français · Niveau : Intermédiaire

Les étapes d'une analyse de risques et la construction d'une matrice de criticité croisant probabilité d'occurrence et gravité. Le prolongement direct de la leçon 3 : compare leurs échelles à celles utilisées dans notre matrice de Sahel Négoce.

https://www.youtube.com/watch?v=Qpv-_s4GaQM

### Leçon 3 — [Webinar] EBIOS RM × GRC : connecter analyse de risque et conformité (Make IT Safe × ALL4TEC)

Chaîne : Make IT Safe - Logiciel Cybersécurité & Conformité · Langue : Français · Niveau : Avancé

Un webinaire professionnel qui relie la méthode d'analyse de risque EBIOS Risk Manager (ANSSI) au pilotage de la conformité. Il montre comment les risques évalués alimentent concrètement les plans de traitement suivis dans le temps.

https://www.youtube.com/watch?v=9BKCDQCAo3w

### Leçon 4 — Formation ISO/IEC 27001:2022 — Management de la sécurité de l'information

Chaîne : Management Qualité · Langue : Français · Niveau : Intermédiaire à avancé

Une formation structurée en modules sur les exigences du SMSI et les familles de mesures de sécurité, y compris les preuves attendues en audit. Utile pour situer les contrôles testés dans la leçon 4 dans le paysage complet d'un référentiel.

https://www.youtube.com/watch?v=KVOOIXJn6jw

### Leçon 4 — Sauvegardes informatiques : l’erreur qui peut ruiner un audit ?

Chaîne : Audit et Contrôle interne · Langue : Français · Niveau : Intermédiaire

Le point de vue d'auditeurs sur le contrôle des sauvegardes et de la reprise : ce qui est attendu, ce qui est testé, et les erreurs qui font échouer un audit. À regarder en pensant au contrôle C-05 de notre cas fil rouge.

https://www.youtube.com/watch?v=Fcss2XE9vbQ

## Sources et références

• Programme officiel Licence Informatique, Université IAM (Institut Africain de Management), Bamako — vérifier les intitulés d'UE auprès du secrétariat

pédagogique.

• Famille de normes ISO/IEC 27000 (management de la sécurité de l'information) et référentiel COBIT de l'ISACA : cadres de référence à consulter en bibliothèque — ce cours en présente les principes sans en reproduire le contenu.

• Publications gratuites de l'ANSSI (agence nationale française de la sécurité des systèmes d'information), notamment la présentation de la méthode EBIOS Risk Manager — ssi.gouv.fr.

• Guides publics sur la protection des données personnelles applicables au Mali (loi relative à la protection des données à caractère personnel et autorité de protection) — à consulter dans leur version officielle en vigueur.

• Les vidéos listées dans la section « Vidéos associées aux leçons » de ce document (liens vérifiés à la publication).

Fin du cours — Bronbah Tech, Bibliothèque Universitaire IAM. Bon courage pour tes révisions !

# Mes notes

Utilise ces pages pour recopier les définitions, refaire les calculs et noter tes questions pour le prochain cours.